

ملخص

الفصل الأول: تهديدات أمن الشبكات الحديثة (Modern Network Security Threats)

❖ مفاهيم أمن الشبكات الأساسية (Network Security Fundamentals)

• الغرض من الأمن (Purpose of Security):

- الهدف هو حماية الأصول.
- تاريخياً، كان الأمن يتم من خلال الأمن المادي (Physical Security) والشبكات المغلقة (Closed Networks).
- الرسم التوضيحي (شريحة 3): تقوم فكرة "الشبكة المغلقة" (Closed Network) على ربط المواقع الرئيسية بالقنوات والمستخدمين عن بُعد عبر خطوط مسنّجة (Frame Relay X.25 Leased Line) أو شبكة الهاتف العامة (PSTN) دون الاتصال بالإنترنت العام، مما يعزلها مادياً عن المهاجمين الخارجيين.

• مصطلحات أمن الشبكات الشائعة (Common Network Security Terms):

- التهديد (Threat): احتمالية تحول الثغرات الأمنية إلى هجوم شبكي.
- الثغرة الأمنية (Vulnerability): نقطة ضعف أو خلل في الشبكة.
- التخفيف (Mitigation): إجراء لتقليل خطورة الثغرة الأمنية.
- الخطر (Risk): احتمالية قيام التهديد باستغلال الثغرات الأمنية.

• مصطلحات أمن الحاسوب (Computer Security Terminology):

- الثغرة الأمنية (Vulnerability): نقطة ضعف يمكن للمهاجم استغلالها لصالحه، مثل:
 - البيئة المادية، الأخطاء البرمجية.
 - عيوب تصميم النظام/البروتوكول.
 - كلمات المرور الضعيفة.
- التهديد (Threat): حدث أو ظرف يتسبب في إلحاق الضرر بالأنظمة، وقد يستغل ثغرة أمنية، مثل:
 - مادي (حريق، ماء، زلازل).
 - أكواد خبيثة (فيروس، أحصنة طروادة، برمجيات خبيثة).
 - التصيد الاحتيالي، الهندسة الاجتماعية.
- الاستغلال (Exploit): آلية أو أداة تُستخدم للاستفادة من ثغرة أمنية لاختراق أمن النظام أو وظائفه (قد تكون سلسلة من الأوامر، أو جزء من برنامج، أو كتلة من البيانات).
- الخطر (Risk): احتمالية وقوع تهديد أو حدث معين:
 - لا يمكن الحد من المخاطر الأمنية بشكل كامل.
 - الخطر المتبقي يُسمى "الخطر المتبقي" (Residual Risk) أو "الخطر المقبول" (Accepted Risk).

• نماذج أمن الشبكات (Network Security Models):

• تُطبق سياسة الأمن (Security Policy) على: أمن شبكة المؤسسة (Enterprise Network Security) وأمن التطبيقات (Application Security).

وجه المقارنة	نموذج الأمن المفتوح (Open Security Model)	نموذج الأمن المقيد (Restrictive Security Model)	نموذج الأمن المغلق (Closed Security Model)
المبدأ	السماح بكل شيء لم يتم منعه صراحةً.	مزيج من أدونات محددة وقيود محددة.	منع كل شيء لم يتم السماح به صراحةً.
الميزة	يحقق "سهولة وصول المستخدم" (Transparent User Access).	يحقق حالة من التوازن بين "الوصول" (Access) و"الأمن" (Security).	يحقق "أقصى درجات الأمن" (Maximum Security).
الخصائص	- سهل التكوين والإدارة. - سهل مستخدم في الشبكة. - تكلفة الأمن (أقل تكلفة).	- أكثر صعوبة في التكوين والإدارة. - أكثر صعوبة لمستخدمي الشبكة. - تكلفة الأمن (أكثر تكلفة).	- الأكثر صعوبة في التكوين والإدارة. - الأكثر صعوبة لمستخدمي الشبكة. - تكلفة الأمن (الأكثر تكلفة على الإطلاق).

• نواقل هجمات الشبكة (Vectors of Network Attacks):

• تعريف ناقل الهجوم (Attack Vector):

- هو مسار أو وسيلة أخرى يمكن للمهاجم من خلالها الوصول إلى الخادم.
- أو هو التقنية التي يمكن للمخترقين من خلالها الحصول على وصول غير مصرح به إلى جهاز أو شبكة لأغراض خبيثة.
- تتشأ العديد من نواقل الهجوم من خارج شبكة المؤسسة (التهديدات الخارجية) ومن داخل الشبكة (التهديدات الداخلية).
- يمكن أن يسبب "التهديد الداخلي" (Internal Threat) أضراراً أكبر من "التهديد الخارجي" (External Threat)، لأن المستخدم الداخلي لديه وصول مباشر إلى الشبكة.
- يجب على متخصصي أمن الشبكات تطبيق أدوات واستخدام تقنيات لتخفيف التهديدات الخارجية والداخلية على حد سواء.

• فقدان البيانات (Data Loss)؛

- من المرجح أن تكون البيانات هي الأصل الأكثر قيمة للمؤسسة (مثل بيانات البحث والتطوير، بيانات المبيعات، البيانات المالية، والبيانات القانونية)، فيجب على متخصصي أمن الشبكات حماية بيانات المؤسسة.
- يحدث فقدان/ تسريب البيانات (Data Loss/Exfiltration) عندما تُفقد البيانات أو تُسرق أو تُسرب إلى العالم الخارجي بقصد أو بدون قصد، لذلك يجب تطبيق مختلف ضوابط "منع فقدان البيانات" (Data Loss Prevention - DLP).
- نواقل فقدان البيانات (Vectors of Data Loss)؛
 - البريد الإلكتروني/ بريد الويب (الرسائل الفورية).
 - الأجهزة غير المشفرة (تخزين البيانات بدون خوارزمية تشفير على الأجهزة).
 - أجهزة التخزين السحابي (عند اختراق الوصول إليها).
 - الوسائط القابلة للإزالة، والنسخ الورقية المطبوعة.
 - التحكم غير السليم في الوصول (كلمات مرور مسروقة/ ضعيفة).

❖ نظرة عامة على طوبولوجيا الشبكة (Network Topology Overview)

○ عادةً تُحفظ شبكات مركز البيانات في منشأة خارج الموقع (Off-site facility) لتخزين البيانات الحساسة أو الخاصة. ○ ترتبط هذه المواقع بمواقع الشركة باستخدام تقنية VPN مع أجهزة ASA وسويتشات (switches) مركز البيانات المدمجة. ○ تخزن مراكز البيانات اليوم كميات هائلة من المعلومات الحساسة والمهمة للأعمال، لذا يُعد الأمن المادي (physical security) أمراً بالغ الأهمية لتشغيلها. ○ يمكن تقسيم الأمن المادي لمركز البيانات (Data Center Physical Security) إلى منطقتين: ➤ أمن المحيط الخارجي (Outside perimeter security)؛ ▪ حراس أمن في الموقع. ▪ أسوار وبوابات. ▪ مراقبة مستمرة بالفيديو. ▪ إنذارات خرق الأمن. ➤ أمن المحيط الداخلي (Inside perimeter security)؛ ▪ كاشفات الحركة الإلكترونية. ▪ مصائد أمنية. ▪ مراقبة مستمرة بالفيديو. ▪ مستشعرات الدخول والخروج البيومترية. ملاحظة: الأمن المادي لا يحمي فقط الوصول إلى المنشأة، بل يحمي أيضاً الأشخاص والمعدات. ○ مكونات مركز البيانات الآمن (Components of a Secure Data Center)؛ ➤ التجزئة الآمنة (Secure Segmentation). ➤ الدفاع ضد التهديدات (Threat Defense). ➤ الرؤية/الوضوح (Visibility).	شبكات مركز البيانات (Data Center Networks)
○ التهديدات الخاصة بالأجهزة الافتراضية (VM-specific threats)؛ ➤ اختطاف المراقب الافتراضي (Hyperjacking)؛ يمكن للمهاجم اختطاف VM Hypervisor واستخدامه كنقطة انطلاق لمهاجمة الأجهزة الأخرى في شبكة مركز البيانات. ➤ التنشيط الفوري (Instant On activation)؛ تفعيل VMs الغامضة غير المعجبة. ➤ عاصفة مكافح الفيروسات (Antivirus storm)؛ تحدث عند تشغيل الفحص في آن واحد على عدة VMs. ○ الحوسبة السحابية والافتراضية (Cloud Computing and Virtualization)؛ ➤ الافتراضية (Virtualization)؛ هي أساس الحوسبة السحابية، بدونها لن تكون الحوسبة السحابية ممكنة بالشكل المطبق على نطاق واسع حالياً. ➤ تفصل "الحوسبة السحابية" التطبيق (Application) عن العتاد المادي (Hardware). ➤ بينما تفصل "الافتراضية" نظام التشغيل (OS) عن العتاد المادي (Hardware). ➤ تتيح الحوسبة السحابية للمؤسسات استخدام خدمات (مثل تخزين البيانات والتطبيقات المستندة إلى السحابة) لتوسيع قدراتها أو إمكانياتها دون إضافة بنية تحتية. ➤ تتكون الشبكة السحابية الفعلية من "خوادم مادية وافتراضية" (physical and virtual servers) تُستضاف عادةً في مراكز البيانات.	الشبكات السحابية والافتراضية (Cloud and Virtual Networks)

❖ الحدود المتطورة للشبكة (The Evolving Network Border)

- في الماضي، كان الموظفون وموارد البيانات يبقون داخل محيط محدد مسبقاً ومحمي بجدار حماية، لكن اليوم لدينا مفهوم "أحضر جهازك الخاص" (BYOD)، لذا طورت سيسكو ما يُسمى بـ "الشبكة بلا حدود" (Borderless Network).

• إدارة الأجهزة المحمولة (Mobile Device Management - MDM)؛

- وظائف "MDM" اللازمة لشبكة "BYOD" (Critical MDM functions for BYOD network)؛
 - تشفير البيانات (Data encryption).
 - فرض رمز/ قفل "PIN" (PIN enforcement/PIN lock).
 - مسح البيانات عن بُعد (Data wipe) عبر نظام "MDM".

◀ منع فقدان البيانات (Data Loss Prevention - DLP).

◀ الكشف عن كسر الحماية/الروت (Jailbreak/root detection).

○ تتميز وظائف "MDM" بتأمين ومراقبة وإدارة الأجهزة المحمولة، بما في ذلك الأجهزة المملوكة للشركة والأجهزة المملوكة للموظفين.

❖ المخترق وتطور المخترقين (The Hacker & The Evolution of Hackers)

• تعريف الهاكر (Hacker): يحمل مصطلح "هاكر" معاني متنوعة:

○ مبرمج ذكي (A Clever Programmer).

○ متخصص شبكات يستخدم مهارات برمجية متطورة لضمان عدم تعرض الشبكات للهجوم.

○ شخص يحاول الحصول على وصول غير مصرح به إلى الأجهزة على الإنترنت.

○ أفراد يقومون بتشغيل برامج لمنع أو إبطاء وصول عدد كبير من المستخدمين للشبكة، أو إتلاف أو مسح البيانات على الخوادم.

• تطور/أنواع المخترقين (The Evolution of Hackers):

◀ ذو القبة البيضاء (White Hat).

◀ ذو القبة السوداء (Black Hat).

◀ ذو القبة الرمادية (Grey Hat).

• تاريخ الاختراق (History of Hacking):

○ بدأ الاختراق في ستينيات القرن الماضي (1960) مع ظاهرة "التلاعب بالهاتف" (phone freaking/phreaking)، والتي تشير إلى استخدام ترددات صوتية مختلفة للتلاعب بأنظمة الهاتف.

○ في منتصف الثمانينيات (1985)، استُخدمت "أجهزة المودم الهاتفية" (dial-up modems) لتوصيل أجهزة الحاسوب بالشبكات. وطور المخترقون برامج "الاتصال الحربي" (war dialing) التي تتصل بكل رقم هاتف في منطقة معينة بحثاً عن أجهزة الحاسوب، ثم استُخدمت برامج كسر كلمات المرور للوصول.

• عناوين الاختراق الحديثة (Modern Hacking Titles):

أطفال النص البرمجي (Script Kiddies)	◀ فرد غير ماهر يستخدم "نصوصاً برمجية"، أو برامج تم تطويرها بواسطة آخرين، لمهاجمة أنظمة الحاسوب والشبكات وتشويه مواقع الويب.
وسطاء الثغرات الأمنية (Vulnerability Brokers)	◀ شخص يشتري ويكشف الثغرات لبيعها للجهات الأمنية أو الشركات.
النشطاء المخترقون (HacktivistHs)	◀ شخص يخترق نظام حاسوب لتحقيق هدف سياسي أو اجتماعي. ◀ إحدى مجموعات النشطاء هي "ويكيليكس" (Wikileaks) وهو اختراق لفت الانتباه.
المجرمون السيبرانيون (Cyber Criminals)	◀ هم مخترقو ذو القبة السوداء بدافع جني الأموال بأي وسيلة كانت. ◀ يعملون في ظل اقتصاد سري تحت الأرض، حيث يشترون ويبيعون ويتاجرون بـ (أدوات الهجوم attack toolkits)، أكواد استغلال يوم الصفر، خدمات البوتنت "botnet"، تروجانات البنوك (banking Trojans)، برامج تسجيل نقرات المفاتيح (keyloggers)، وغير ذلك.
مخترقون برعاية دول (State-Sponsored Hackers)	◀ هم أحدث أنواع المخترقين، مهاجمون تمولهم وتوجههم حكومات، ويكلفون بشن عمليات متنوعة بين التجسس الإلكتروني (cyber espionage) وسرقة الملكية الفكرية (intellectual property). ترعى العديد من الدول هؤلاء المخترقين ولكن القليل منها تعترف علناً.

• تطور أدوات الأمن (Evolution of Security Tools):

○ يتضمن "الاختراق الأخلاقي" (Ethical Hacking) عدة أنواع من الأدوات المختلفة لاختبار الشبكة وبياناتها والحفاظ على أمنها.

○ للتحقق من أمن الشبكة وأنظمتها، تم تطوير العديد من أدوات اختبار اختراق الشبكة.

○ مع ذلك، يمكن استخدام العديد من هذه الأدوات أيضاً من قبل مخترقي "القبة السوداء" (black hat) لغرض الاستغلال.

أدوات اختبار الاختراق (Penetration Testing Tools)		
1	أدوات كسر كلمة المرور (Password crackers)	
2	أدوات اختراق الشبكات اللاسلكية (Wireless hacking)	
3	أدوات فحص الشبكة واختراقها (Network scanning and hacking)	
4	أدوات صياغة الحزم (Packet crafting)	إنشاء حزمة مخصصة وفقاً لمتطلبات مختلفة، لشن الهجمات واستغلال الثغرات في الشبكة (مثل أداة "Netcat").
5	أدوات التقاط الحزم (Packet sniffers)	
6	أدوات اكتشاف الروت كيت (Rootkit detectors)	برنامج التحقق من سلامة المجلدات والملفات.
7	أدوات Fuzzers للبحث عن الثغرات (Fuzzers to search vulnerabilities)	تُستخدم لمحاولة اكتشاف الحالة الأمنية لنظام الحاسوب عبر إرسال بيانات غير متوقعة.
8	أدوات التحقيق الجنائي الرقمي (Forensic)	تُستخدم لتقصي وتنبع أي أثر للأدلة الموجودة في نظام حاسوب معين.
9	مصححات الأخطاء (Debuggers)	هي برنامج حاسوب يُستخدم لاختبار وتصحيح أخطاء البرامج الأخرى (البرنامج المستهدف).
10	أنظمة تشغيل الاختراق (Hacking operating systems)	مثل نظام "Kali Linux".
11	التشفير (Encryption)	
12	استغلال الثغرات الأمنية (Vulnerability exploitation)	
13	ماسحات الثغرات الأمنية (Vulnerability Scanners)	

• فئات أدوات الهجوم (Categories of Attack Tools)؛

هجمات اختراق الشبكة (Network hacking attacks)		
1	التتبع (Eavesdropping)	يحدث عندما يلتقط المخترق حركة مرور الشبكة و"يستمع" إليها. يُشار إلى هذا الهجوم أيضاً بـ "الالتقاط" (sniffing) أو "التجسس" (snooping).
2	تعديل البيانات (Data modification)	
3	انتحال عنوان IP (IP address spoofing)	
4	هجمات قائمة على كلمات المرور (Password-based)	
5	حجب الخدمة (Denial-of-service - DoS)	
6	رجل في المنتصف (Man-in-the-middle - MitM)	
7	المفتاح المخترق (Compromised-key)	إذا حصل المخترق على مفتاح سري، يُشار لهذا المفتاح بـ "المفتاح المخترق". ويمكن استخدامه للوصول إلى اتصال آمن دون علم المرسل أو المستقبل بالهجوم.
8	المتنصت /الملتقط (Sniffer)	تطبيق أو جهاز يمكنه قراءة ومراقبة والتقاط عمليات تبادل بيانات الشبكة وقراءة حزم الشبكة.

❖ البرمجيات الخبيثة (Malware)

• البرمجيات الخبيثة (Malware): هي وسيلة لتسليم الحمولة الضارة (payload)، وعند تسليمها وتثبيتها يمكن استخدامها لشن مجموعة متنوعة من الهجمات المتعلقة بالشبكة.

◦ مربعان النصب (شريحة 36):

< الفيروس (Virus): برنامج خبيث ينفذ وظيفة محددة غير مرغوب فيها، وغالباً ما تكون ضارة على جهاز الحاسوب.

< الدودة (Worm): تنفذ كوداً عشوائياً وتثبت نسخاً من نفسها في ذاكرة الحاسوب المصاب، بغرض تكرار نفسها تلقائياً والانتشار الذاتي عبر الشبكة من نظام إلى آخر.

< حصان طروادة (Trojan Horse): نوع من البرمجيات الخبيثة غير ذاتية التكرار، وغالباً ما يجنوي على كود خبيث مخفي، ومصمم ليبدو كشيء آخر نافع (مثل تطبيق أو ملف مشروع). وعند تنزيل التطبيق أو الملف المصاب وفنحه، يمكن لحصان طروادة مهاجمة الجهاز النهائي من الداخل.

• أنواع مختلفة من البرمجيات الخبيثة (Various Types of Malware):

- الفيروسات (Viruses) - أحصنة طروادة (Trojan Horses)	- الفيروس: هو كود خبيث يرفق بملفات قابلة للتنفيذ (Executable files) وغالباً ما تكون برامج مشروعة. - يتطلب تنشيطاً من المستخدم النهائي، ويمكن أن يظل خاملاً لفترة طويلة ثم ينشط في وقت أو تاريخ محدد. - حصان طروادة: هو برنامج خبيث ينفذ عمليات ضارة تحت غطاء وظيفة مرغوبة، ويأتي بكود خبيث مخفي بداخله. - لا يستطيع تكرار نفسه تلقائياً، ولا يمكنه الانتشار دون مساعدة أو تفاعل المستخدم النهائي. - التصنيفات (Classification): تُصنف أحصنة طروادة وفقاً للضرر الذي تسببه أو الطريقة التي تخترق بها النظام:													
	<table border="1"> <tr> <td>معطل برامج الأمان (Security software disabler)</td><td>يوقف برامج مكافحة الفيروسات أو جدران الحماية عن العمل.</td></tr> <tr> <td>وصول عن بعد (Remote-access)</td><td></td></tr> <tr> <td>إرسال البيانات (Data-sending)</td><td>سرقة البيانات الحساسة وإرسالها للمهاجم.</td></tr> <tr> <td>تدميري (Destructive)</td><td>يتلف أو يحذف الملفات.</td></tr> <tr> <td>وكيل (Proxy)</td><td>يستخدم حاسوب الضحية كجهاز مصدر لشن الهجمات وتتمير الأنشطة غير قانونية.</td></tr> <tr> <td>FTP</td><td>يُتيح تشغيل خدمات نقل ملفات غير مصرح بها على الأجهزة النهائية.</td></tr> <tr> <td>حجب الخدمة (DoS)</td><td>يبطئ أو يوقف نشاط الشبكة.</td></tr> </table>	معطل برامج الأمان (Security software disabler)	يوقف برامج مكافحة الفيروسات أو جدران الحماية عن العمل.	وصول عن بعد (Remote-access)		إرسال البيانات (Data-sending)	سرقة البيانات الحساسة وإرسالها للمهاجم.	تدميري (Destructive)	يتلف أو يحذف الملفات.	وكيل (Proxy)	يستخدم حاسوب الضحية كجهاز مصدر لشن الهجمات وتتمير الأنشطة غير قانونية.	FTP	يُتيح تشغيل خدمات نقل ملفات غير مصرح بها على الأجهزة النهائية.	حجب الخدمة (DoS)
معطل برامج الأمان (Security software disabler)	يوقف برامج مكافحة الفيروسات أو جدران الحماية عن العمل.													
وصول عن بعد (Remote-access)														
إرسال البيانات (Data-sending)	سرقة البيانات الحساسة وإرسالها للمهاجم.													
تدميري (Destructive)	يتلف أو يحذف الملفات.													
وكيل (Proxy)	يستخدم حاسوب الضحية كجهاز مصدر لشن الهجمات وتتمير الأنشطة غير قانونية.													
FTP	يُتيح تشغيل خدمات نقل ملفات غير مصرح بها على الأجهزة النهائية.													
حجب الخدمة (DoS)	يبطئ أو يوقف نشاط الشبكة.													
الديدان (Worms)	- الديدان: هي برمجيات خبيثة تكرر نفسها عن طريق استغلال الثغرات الأمنية في الشبكات بشكل مستقل، وتسبب عادةً في إبطاء أداء الشبكات. - يمكنها العمل والانتشار بمفردها تماماً. - تتكون معظم هجمات الديدان من ثلاث مكونات (Most worm attacks consist of three Components):													
	<table border="1"> <tr> <td>الثغرة التمكينية (Enabling vulnerability)</td><td>تُثبت الدودة نفسها باستخدام آلية استغلال (مثل مرفق بريد إلكتروني، أو ملف قابل للتنفيذ، أو عبر حصان طروادة) على نظام مصاب بالثغرة.</td></tr> <tr> <td>آلية الانتشار (Propagation mechanism)</td><td>بعد الوصول إلى الجهاز، تقوم الدودة بنسخ نفسها تلقائياً والبحث عن أهداف جديدة.</td></tr> <tr> <td>الحمولة الضارة (Payload)</td><td>هي أي كود خبيث ينتج إجراء، وغالباً ما تُستخدم لإنشاء "باب خلفي" (backdoor) للجهاز المصاب أو لشن هجمات "DoS".</td></tr> </table>	الثغرة التمكينية (Enabling vulnerability)	تُثبت الدودة نفسها باستخدام آلية استغلال (مثل مرفق بريد إلكتروني، أو ملف قابل للتنفيذ، أو عبر حصان طروادة) على نظام مصاب بالثغرة.	آلية الانتشار (Propagation mechanism)	بعد الوصول إلى الجهاز، تقوم الدودة بنسخ نفسها تلقائياً والبحث عن أهداف جديدة.	الحمولة الضارة (Payload)	هي أي كود خبيث ينتج إجراء، وغالباً ما تُستخدم لإنشاء "باب خلفي" (backdoor) للجهاز المصاب أو لشن هجمات "DoS".							
الثغرة التمكينية (Enabling vulnerability)	تُثبت الدودة نفسها باستخدام آلية استغلال (مثل مرفق بريد إلكتروني، أو ملف قابل للتنفيذ، أو عبر حصان طروادة) على نظام مصاب بالثغرة.													
آلية الانتشار (Propagation mechanism)	بعد الوصول إلى الجهاز، تقوم الدودة بنسخ نفسها تلقائياً والبحث عن أهداف جديدة.													
الحمولة الضارة (Payload)	هي أي كود خبيث ينتج إجراء، وغالباً ما تُستخدم لإنشاء "باب خلفي" (backdoor) للجهاز المصاب أو لشن هجمات "DoS".													
	- دورة حياة دودة "Code Red" (Code Red Worm Propagation): - الانتشار لـ 19 يوماً. - شن هجوم "DoS" للأيام السبعة التالية. - التوقف والدخول في مرحلة خمول لبضعة أيام. - تكرار الدورة مجدداً.													
برمجيات خبيثة أخرى (Other Malware)														
برمجيات الفدية (Ransomware)	مصممة لحظر ومنع الوصول إلى نظام الحاسوب حتى يتم دفع مبلغ من المال.													
برمجيات التجسس (Spyware)	تُستخدم لجمع معلومات حول المستخدم وإرسالها إلى جهة أخرى دون موافقة المستخدم.													
برمجيات الإعلانات (Adware)	تعرض عادةً نوافذ منبثقة مزعجة لتحقيق أرباح لمطورها.													
برمجيات التخويف (Scareware)	مصممة لخداع وإرباب المستخدم لدفعه لشراء وتثبيت برامج غير ضرورية ويحتمل أن تكون خطيرة (مثل برامج مكافحة الفيروسات المزيفة).													
التصيد الاحتيالي (Phishing)	محاولة الحصول على معلومات حساسة (مثل أسماء المستخدمين، وكلمات المرور، وتفاصيل بطاقات الائتمان) غالباً لأسباب خبيثة من خلال التظاهر ككيان موثوق في المراسلات الإلكترونية.													
الجذور الخفية (Rootkits)	حزمة برمجيات خبيثة غالباً، مصممة لتمكين الوصول إلى جهاز حاسوب أو مناطق معينة في برمجياته والتي لا يُسمح بالوصول إليها في الوضع الطبيعي مع إخفاء وجودها.													

❖ أنواع هجمات الشبكة (Types of Network Attacks)

○ الغرض منها : يستخدمها المخترقون للقيام باكتشاف غير مصرح به ورسم خرائط للأنظمة ، أو الخدمات النشطة ، أو الثغرات الأمنية . ○ يعرف الاستطلاع بعملية جمع المعلومات (Information gathering) . ○ بعض التقنيات التي يستخدمها المخترقون أثناء هجمات الاستطلاع (techniques hackers use during reconnaissance attacks) : ○ الاستعلام الأولي عن الهدف (Initial query of a target) . ○ مسح شامل للشبكة المستهدفة (Ping sweep of the target network) . ○ فحص المنافذ لعناوين IP النشطة (Port scan of active IP addresses) . ○ استخدام مسحات الثغرات الأمنية (Vulnerability scanners) . ○ استخدام أدوات الاستغلال (Exploitation tools) .	هجمات الاستطلاع (Reconnaissance Attacks)
○ تستغل الثغرات الأمنية المعروفة في خدمات المصادقة (authentication) ، وخدمات FTP ، وخدمات الويب ، للوصول إلى حسابات الويب ، وقواعد البيانات السرية ، والمعلومات الحساسة الأخرى . ○ لماذا يستخدم المخترقون هجمات الوصول (why hackers use access attacks) ؟ ○ لاسترجاع البيانات (To retrieve data) . ○ للحصول على الوصول (To gain access) . ○ لتصعيد امتيازات الوصول (To escalate access privileges) . ○ أنواع هجمات الوصول (types of access attacks) تشمل : ○ كسر كلمات المرور (Password) . ○ استغلال الثقة بين الأنظمة (Trust exploitation) . ○ إعادة توجيه المنافذ (Port redirection) . ○ رجل في المنتصف (Man-in-the-middle - MitM) . ○ تجاوز سعة المخزن المؤقت (Buffer overflow) . ○ انتحال عناوين IP ، و MAC ، و DHCP spoofing (IP, MAC, DHCP spoofing) .	هجمات الوصول (Access Attacks)
○ مصدران رئيسيان لهجمات "DoS" (Two major sources of DOS attacks) : ○ حزم منسقة بشكل خبيث (Maliciously formatted packet) : تتسبب في تعطل الجهاز المستقبل أو عمله ببطء شديد . ○ كميات هائلة من حركة المرور (Overwhelming quantity of traffic) : تعجيز الشبكة أو الجهاز المضيف أو التطبيق عن التعامل مع كميات هائلة من البيانات ، مما يؤدي لتعطل النظام أو بطء الأداء . ○ أنواع هجمات "DoS" (Types of DOS) : ○ بنق الموت (ping of death) . ○ هجوم "smurf" (smurf attack) . ○ إغراق "TCP SYN" (TCP SYN flood) .	هجمات حجب الخدمة (DoS Attacks)
○ الفرق بين "DoS" و "DDoS" : ○ هجوم "DoS" يستخدم عادةً جهاز حاسوب واحد أو اتصال إنترنت واحد لإغراق نظام أو مورد مستهدف . ○ بينما هجوم "DDoS" يستخدم أجهزة حاسوب متعددة واتصالات إنترنت متعددة لإغراق المورد المستهدف . ○ آلية/خطوات تنفيذ هجوم "DDoS" (A DDoS attack could proceed as follows) : ○ يقوم المخترق ببناء شبكة من الأجهزة المصابة : ▪ تُسمى شبكة الأجهزة المصابة بـ "شبكة البوت نت" (Botnet) . ▪ تُسمى أجهزة الكمبيوتر المخترقة بـ "أجهزة الزومبي" (Zombies) . ▪ تتم إدارة أجهزة الزومبي (zombies) عبر أنظمة المعالجة والتحكم (handler systems) . ○ تستمر أجهزة الزومبي (zombies) في فحص وإصابة المزيد من الأهداف (توسيع رقعة البوتنت) . ○ يواجه المخترق نظام المعالجة (handler system) لجعل شبكة الزومبي تنفذ هجوم "DDoS" .	هجمات حجب الخدمة الموزعة (DDoS Attacks)

❖ أمن الشبكات (Networks Security)

• علم التشفير (Cryptography) :

- هو دراسة وممارسة إخفاء المعلومات ، يُستخدم على نطاق واسع في أمن الشبكات الحديثة .
- بالإضافة إلى منع وحظر حركة المرور الخبيثة ، يجب على متخصصي أمن الشبكات أيضاً ضمان حماية البيانات .
- يضمن علم التشفير 3 مكونات لأمن المعلومات – (ثالوث "CIA") :

السرية (Confidentiality)	استخدام التشفير (encryption) لتشفير وإخفاء البيانات .
السلامة (Integrity)	استخدام خوارزميات التجزئة (Hashing) لضمان عدم تعديل البيانات أثناء التشغيل .

- مجالات أمن الشبكات (Network Security Domains) – معيار "ISO/IEC 27002":
 - يجب على متخصصي الشبكات فهم أمن الشبكات، والإلمام بالمنظمات المتخصصة في هذا المجال، فضلاً عن مجالات أمن الشبكات الـ 12.
 - توفر هذه المجالات إطار عمل لمناقشة أمن الشبكات.
 - مجالات أمن الشبكات الـ 12 المحددة وفق معيار "ISO/IEC 27002":
 - تقييم المخاطر (Risk Assessment).
 - سياسة الأمان (Security Policy).
 - تنظيم أمن المعلومات (Organization of information security).
 - إدارة الأصول (Asset Management).
 - أمن الموارد البشرية (Human resources security).
 - الأمن المادي والبيئي (Physical and environmental security).
 - إدارة الاتصالات والعمليات (Communications and operations management).
 - اقتناء نظم المعلومات وتطويرها وصيانتها (Information systems acquisition, development, and maintenance).
 - التحكم في الوصول (Access control).
 - إدارة حوادث أمن المعلومات (Information security incident management).
 - إدارة استمرارية الأعمال (Business continuity management).
 - الامتثال (Compliance).

- الدفاع عن الشبكة – أفضل الممارسات (Defending the Network - Best practices):
 - تطوير سياسة أمن مكتوبة (written security policy).
 - تنفيذ الموظفين بمخاطر الهندسة الاجتماعية، وتطوير استراتيجيات للتحقق من الهويات، عبر الهاتف أو البريد الإلكتروني أو شخصياً.
 - التحكم في الوصول المادي إلى الأنظمة (Control physical access to systems).
 - استخدام كلمات مرور قوية وتغييرها باستمرار.
 - تشفير البيانات الحساسة وحمايتها بكلمات مرور.
 - تثبيت أجهزة وبرامج أمنية (security hardware and software).
 - إجراء نسخ احتياطي واختبار ملفات النسخ الاحتياطي بانتظام.
 - إيقاف الخدمات والمنافذ غير الضرورية.
 - الحفاظ على تحديثات التصحيحات (patches)، بتثبيتها أسبوعياً أو يومياً، لمنع هجمات تجاوز سعة المخزن المؤقت وتصعيد الامتيازات.
 - إجراء عمليات تدقيق أمنية لاختبار الشبكة.

الفصل الثاني: تأمين أجهزة الشبكة (Securing Network Devices)

❖ نهج أمن راوتر الحافة (Edge Router Security Approaches)

- يختلف تطبيق "راوتر الحافة" (Edge Router) بناءً على حجم المؤسسة وتعقيد تصميم الشبكة المطلوب.
- يمكن أن تشمل تطبيقات الراوتر: راوتر واحد يحمي شبكة داخلية بأكملها، أو راوتر يعمل كخط دفاع أول ضمن "نهج الدفاع العميق" (defense-in-depth).

➤ يتم تكوين جميع سياسات الأمن على هذا الجهاز.	➤ نهج الراوتر الفردي
➤ يستخدم بشكل شائع في تطبيقات المواقع الأصغر (مثل الفروع والمكاتب الصغيرة (SOHO)).	➤ (Single Router Approach)
➤ يستخدم طبقات متعددة من الأمن قبل دخول حركة المرور إلى الشبكة المحلية المحمية (protected LAN).	➤ نهج الدفاع العميق
➤ مثال: راوتر خارجي R1 يليه جدار حماية ثم راوتر داخلي R2.	➤ (Defense in Depth Approach)
➤ هوشكل مختلف (variation) من نهج الدفاع العميق.	➤ نهج المنطقة المنزوعة السلاح (DMZ Approach)

• ثلاثة مجالات لأمن الراوتر (Three Areas of Router Security):

➤ وضع الراوتر والأجهزة المادية المتصلة به في غرفة آمنة ومقفلة لا يمكن الوصول إليها إلا للموظفين المصرح لهم، وخالية من التدخل الكهربائي أو المغناطيسي، وبها نظام إخماد الحرائق وتحكم في درجة الحرارة والرطوبة.	➤ الأمن المادي (Physical Security)
➤ تثبيت مزود طاقة غير منقطع (UPS) أو مولد طاقة احتياطي، والاحتفاظ بمكونات احتياطية.	
➤ تكوين الراوتر بأقصى سعة ممكنة من الذاكرة، حيث يساعد توافر الذاكرة في الحد من المخاطر نتيجة بعض هجمات "DoS" مع دعم نطاق أوسع من الخدمات الأمنية.	➤ أمن نظام التشغيل (OS Security)
➤ استخدام أحدث إصدار مستقر من نظام التشغيل يلي مواصفات ميزات الراوتر أو جهاز الشبكة.	
➤ الاحتفاظ بنسخة آمنة من صور نظام تشغيل الراوتر (OS images) وملفات التكوين (Backups).	
➤ تأمين التحكم الإداري (Secure administrative control).	➤ تدريع الراوتر (Router Hardening)
➤ تعطيل المنافذ والواجهات غير المستخدمة (Disable unused ports and interfaces).	
➤ تعطيل الخدمات غير الضرورية (Disable unnecessary services).	

❖ تأمين الوصول الإداري (Secure Administrative Access)

- يُعد تأمين الوصول الإداري مهمة أمنية بالغة الأهمية.
- المهام المطلوبة (Tasks):
 - تقييد إمكانية الوصول إلى الجهاز (Restrict device accessibility).
 - تسجيل وتتبع جميع عمليات الوصول (Log and account for all access).
 - مصادقة الوصول (Authenticate access).
 - تفويض الإجراءات (Authorize actions).
 - تقديم إشعار قانوني/تحذيري (Present legal notification).
 - ضمان سرية البيانات (Ensure the confidentiality of data) ← حماية البيانات الحساسة والمخزنة محلياً من العرض والنسخ.

❖ تأمين الوصول المحلي وعن بُعد (Secure Local and Remote Access)

- احتياجات يجب اتخاذها عند الوصول إلى الشبكة عن بُعد (network remotely):
 - تشفير جميع حركات المرور بين حاسوب المسؤول والراوتر (مثل بروتوكول SSH).
 - إنشاء شبكة إدارة مخصصة (dedicated management network).
 - تكوين فلتر حزم (packet filter)، للسماح فقط لمضيفي الإدارة المحددين والبروتوكولات المفضلة بالوصول إلى الراوتر.
 - تكوين وإنشاء اتصال "VPN" بالشبكة المحلية قبل الاتصال بمنفذ إدارة الراوتر.

الخطوات التوضيحية (بشركة 64):

- الوصول المحلي (Local Access): من جهاز حاسوب محلي للطرفية عبر اتصال نسلسلي (Serial Connection) إلى منفذ الكونسول (con) في الراوتر.
- الوصول عن بُعد باستخدام "Telnet": اتصال "Telnet" من جهاز حاسوب محلي للطرفية عبر خطوط "VTY" إلى الراوتر.
- الوصول عن بُعد باستخدام المودم ومنفذ "Aux": اتصال نسلسلي عبر شبكة الهاتف العامة (PSTN) ومودم إلى منفذ المساعدة (aux) للراوتر.

❖ تكوين مستويات الصلاحيات (Configuring Privilege Levels)

تقييد توفر الأوامر (Limiting Command Availability):

مستويات الصلاحيات (Privilege levels)	مستويات أوامر الوصول (Levels of access commands)
Level 0: محدد مسبقاً لصلاحيات الوصول على مستوى المستخدم (user-level).	وضع المستخدم (User EXEC mode) – مستوى الصلاحية 1: - أدنى صلاحيات للمستخدم في وضع التنفيذ. - تتوفر فقط أوامر مستوى المستخدم (user-level) عند محث >Router.
Level 1: المستوى الافتراضي لتسجيل الدخول مع ظهور محث الراوتر >Router.	
Level 2-14: يمكن تخصيصها لصلاحيات مستوى المستخدم.	
Level 15: محجوز لصلاحيات وضع التمكين الكامل (enable mode privileges).	وضع الصلاحيات (Privileged EXEC mode) – مستوى الصلاحية 15: تتوفر جميع أوامر مستوى التمكين (enable-level) عند محث #Router.

صيغة تحديد مستوى الصلاحية (Privilege Level Syntax):

Router(config)# privilege mode {level level reset} command	
يحدد وضع التكوين المراد تعديله، يستخدم الأمر privilege لعرض قائمة بأوضاع تكوين الراوتر المتاحة على جهازك.	mode
(اختياري) يحدد مستوى الصلاحية لأمر معين (من 0 إلى 15).	level level
(اختياري) يعيد تعيين مستوى الصلاحية الافتراضي لأمر معين.	reset
يحدد الأمر المعنى.	command

- يحتوي "Cisco IOS" على طريقتين لتوفير الوصول إلى البنية التحتية:
 - مستوى الصلاحية (privilege level)، وواجهة سطر الأوامر المستندة إلى الدور (role-based CLI).
 - تساعد كلتا الطريقتين في تحديد من يُسمح له بالاتصال بالجهاز والإجراءات المسموح له بتنفيذها.

قيود مستويات الصلاحيات (Limitations of Privilege Levels):

- لا يوجد تحكم في الوصول إلى واجهات (interfaces)، أو منافذ (ports)، أو واجهات منطقية (logical interfaces)، أو فتحات (slots) على الراوتر.
- الأوامر المتاحة في مستويات الصلاحيات الأدنى تكون دائماً قابلة للتنفيذ في مستويات الصلاحيات الأعلى (higher Privilege).
- الأوامر المحددة لمستويات الصلاحيات الأعلى لا تكون متاحة لمستخدمي الصلاحيات الأدنى.
- تعيين أمر يتضمن كلمات مفتاحية متعددة يمنح الوصول تلقائياً إلى جميع الأوامر التي تستخدم تلك الكلمات.
- ملاحظة: إذا كان على مسؤول النظام إنشاء حساب مستخدم لديه حق الوصول لعظم الأوامر (وليس جميعها)، فيجب تكوين عبارات "privilege exec" لكل أمر يلزم تنفيذه بمستوى صلاحية أقل من 15.

❖ الوصول إلى واجهة سطر الأوامر المستند إلى الدور (Role-Based CLI Access)

أمثلة على الأدوار (For Example):

صلاحيات مشغل الأمن (Security operator privileges)	صلاحيات مهندس شبكات "WAN" (WAN engineer privileges)
تكوين خدمات "AAA" (Configure AAA).	تكوين التوجيه (Configure routing).
تكوين جدار الحماية (Configure firewall).	تكوين الواجهات (Configure interfaces).

تكوين أنظمة كشف ومنع التسلل (Configure IDS/IPS).	تنفيذ أوامر العرض (Issue show commands).
تكوين بروتوكول "NetFlow" (Configure NetFlow).	
تنفيذ أوامر العرض (Issue show commands).	

- ميزة الوصول إلى "CLI" المستند إلى الدور (Role-Based CLI Access Feature):
 - قدمت سيسكو ميزة الوصول إلى "CLI" المستند إلى الدور في إصدار نظام "Cisco IOS Release 12.3(11)T"، لتوفير مرونة أكبر مما توفره مستويات الصلاحيات التقليدية.
 - تمكن هذه الميزة مسؤولي الشبكة من إنشاء عروض (views) مختلفة لتكوينات الراوتر لمختلف المستخدمين.
 - يحدد كل عرض (view) أوامر "CLI" التي يمكن للمستخدم الوصول إليها.

• العروض المستندة إلى الدور (Role-Based Views):

- توفر "CLI" المستندة إلى الدور (Role-Based CLI) ثلاثة أنواع من العروض:

عرض الجذر (Root View)	يمكن فقط لمستخدم عرض الجذر تكوين عرض جديد وإضافة أو إزالة الأوامر من العروض (views) الحالية.
عرض واجهة سطر الأوامر (CLI View)	يمكن لجميع مجموعة محددة من الأوامر في عرض "CLI" واحد.
العرض الشامل (Superview)	على عكس مستويات الصلاحيات، لا يحتوي عرض "CLI" على تسلسل هرمي للأوامر (لا توجد عروض أعلى أو أدنى).
	يتكون من عرض "CLI" واحد أو أكثر.
	يمكن للمسؤولين تحديد الأوامر المقبولة ومعلومات التكوين المرئية.

- المخطط التوضيحي (شريحة 82): الخلاصة: تحتوي العروض الشاملة (Superviews) على عروض (Views) وليس أوامر مباشرة. ويمكن لعرضين شاملين الإشارة في استخدام نفس العرض (هذا اختراع من 1 Superview و 2 Superview على 4 View).

❖ تأمين صورة نظام تشغيل سيسكو وملفات التكوين (Securing Cisco IOS Image and Configuration Files)

• ميزة التكوين المرنة لـ "Cisco IOS" (Cisco IOS Resilient Configuration Feature):

- تتيح هذه الميزة استرداد أسرع في حال تهيئة ذاكرة الفلاش (flash) أو مسح ملف تكوين بدء التشغيل (startup configuration) في ذاكرة "NVRAM".
- عند تأمين صورة "Cisco IOS"، ترفض ميزة التكوين المرنة جميع طلبات نسخها، أو تعديلها، أو حذفها.
- يتم تخزين صورة آمنة من تكوين بدء التشغيل في ذاكرة الفلاش إلى جانب صورة "IOS" المؤمنة (secure IOS image).
- حزمة الإقلاع (bootset): هي مجموعة ملفات صورة "Cisco IOS" والتكوين قيد التشغيل (running configuration) للراوتر.
- يتوفر أمران للتكوين العام لاعداد ميزات التكوين المرنة: secure boot-image و secure boot-config.

• مربع النص (شريحة 88): حقائق حول ميزة التكوين المرنة (Cisco IOS Resilient Configuration Facts):

- ملف التكوين في حزمة الإقلاع الأساسية هو صورة من التكوين قيد التشغيل الذي كان على الراوتر عند تمكين الميزة لأول مرة.
- تؤمن الميزة أصغر مجموعة عمل من الملفات للحفاظ على مساحة التخزين الدائمة، ولا تطلب مساحة إضافية لتأمين ملف صورة "Cisco IOS" الأساسي.
- تكشف الميزة تلقائياً عدم تطابق إصدار الصورة أو التكوين.
- يُستخدم التخزين المحلي فقط لتأمين الملفات، مما يلغي مخاطر صيانة النوسعة الناجمة عن تخزين صور وتكوينات متعددة على خوادم "TFTP".
- لا يمكن تعطيل هذه الميزة إلا عبر جلسة اتصال مباشر عبر منفذ الكونسول (Console).
- تتوفر هذه الميزة فقط للأنظمة التي تدعم واجهة فلاش "PCMCIA ATA" المتقدمة.

• تكوين النسخ الآمن (Configuring Secure Copy):

- توفر ميزة مرونة "Cisco IOS" طريقة لتأمين صورة "IOS" وملفات التكوين محلياً على الجهاز.
- يتم استخدام ميزة "بروتوكول النسخ الآمن" (Secure Copy Protocol - SCP) لنسخ هذه الملفات عن بُعد.
- يوفر بروتوكول "SCP" طريقة آمنة وموثقة لنسخ ملفات تكوين الراوتر أو ملفات صور نظام الراوتر إلى موقع بعيد.

○ تكوين الراوتر للعمل كخادم "SCP" (server-side SCP) مع خدمات "AAA" المحلية:

- تكوين بروتوكول النقل الآمن (SSH).
- تكوين مستخدم واحد على الأقل بمستوى صلاحية 15.
- تمكين خدمات "AAA" (على الراوتر).
- تحديد استخدام قاعدة البيانات المحلية للمصادقة.
- تكوين تفويض الأوامر (command authorization).
- تمكين وظيفة خادم "SCP" (SCP server-side functionality).

❖ الإدارة الآمنة وأعداد التقارير (Secure Management and Reporting)

• تحديد نوع إدارة الوصول (Determining the Type of Management Access):

الإدارة خارج النطاق (Out-of-Band (OOB) Management)	الإدارة داخل النطاق (In-Band Management)
توفر أعلى مستوى من الأمن.	تُطبق فقط على الأجهزة التي تحتاج إلى إدارة أو مراقبة.
تخفف من مخاطر تمرير بروتوكولات الإدارة عبر شبكة الإنتاج الحية (Production network).	استخدام بروتوكولات IPsec أو SSH أو SSL عند الإمكان.
	تحدد ما إذا كانت قناة الإدارة بحاجة لأن تكون مفتوحة طوال الوقت أم لا.

- رسالة سجل النظام (Syslog Message):

- تُنتج أجهزة سيسكورسال سجل النظام كنتيجة لأحداث الشبكة.
- تحتوي كل رسالة على مستوى خطورة (Severity level) ومرفق (Facility).
- الأرقام الأصغر تمثل الإنذارات الأكثر خطورة في "Syslog".
- يمكن تعيين مستوى خطورة الرسائل للتحكم في مكان عرض كل نوع من الرسائل (مثل عرضها على الكونسول).
- مستويات "Syslog" من (0-4) هي رسائل تتعلق بوظائف البرمجيات أو العتادات.
- مستويات "Syslog" (5 و6) مخصصة للإشعارات والرسائل الإعلامية.

- مستويات الأمان (Security Levels Table):

التعريف (Definition)	الوصف (Description)	الكلمة المفتاحية (Keyword)	المستوى (Level)
LOG_EMERG	النظام غير قابل للاستخدام	emergencies	0
LOG_ALERT	يلزم لاتخاذ إجراء فوري	alerts	1
LOG_CRIT	ظروف حرجية قائمة	critical	2
LOG_ERR	ظروف خطأ قائمة	errors	3
LOG_WARNING	ظروف تحذيرية قائمة	warnings	4
LOG_NOTICE	حالة طبيعية ولكنها هامة	notifications	5
LOG_INFO	رسائل إعلامية فقط	informational	6
LOG_DEBUG	رسائل تصحيح الأخطاء	debugging	7

- أمثلة مستويات الخطورة (Example Severity Levels):

المستوى والاسم (Syslog Level and Name)	الوصف (Description)	مثال (Example)
0 LOG_EMERG	حالة ذعر يتم بثها عادة لجميع المستخدمين.	تعذر تحميل برنامج Cisco IOS.
1 LOG_ALERT	حالة يجب تصحيحها على الفور (مثل تلف قاعدة بيانات النظام).	درجة حرارة الجهاز مرتفعة جداً.
2 LOG_CRIT	ظروف حرجية (مثل أخطاء الأجهزة).	تعذر تخصيص الذاكرة.
3 LOG_ERR	أخطاء عامة.	حجم الذاكرة غير صالح.
4 LOG_WARNING	رسائل تحذيرية.	فشلت عملية التشفير.
5 LOG_NOTICE	ظروف غير خائنة قد تتطلب معالجة خاصة.	تغير حالة الواجهة إلى عمل (Up) أو تعطيل (Down).
6 LOG_INFO	رسائل معلوماتية.	حزمة تم رفضها بواسطة قائمة التحكم بالوصول ACL.
7 LOG_DEBUG	رسائل تحتوي على معلومات تستخدم عادة عند فحص وتصحيح البرنامج.	نوع الحزمة غير صالح.

❖ بروتوكول إدارة الشبكة البسيط (Simple Network Management Protocol - SNMP)

- مقدمة إلى بروتوكول "SNMP" (Introduction to SNMP):

- يتكون بروتوكول "SNMP" من 3 عناصر مرتبطة بنظام إدارة الشبكة (NMS - Network Management System) :

- مدير "SNMP" (SNMP manager).

- ◀ عملاء "SNMP"/العقد المدارة (SNMP agents/managed node).

- قاعدة معلومات الإدارة (Management Information Base - MIB).

- المخطط التوضيحي (شريحة 104): يوضح "مدير SNMP" مُعاملًا جهاز حاسوب يتواصل مع "العقد المُدارة" (مثل الراوتر، والسويتش، والجدار الناري)، حيث يُنوي كل جهاز منها على "عميل SNMP".

- قاعدة معلومات الإدارة (Management Information Base - MIB):

- تمتلك رسائل "SNMP" (set, get, trap) حق الوصول لإنشاء وتعديل المعلومات في "MIB".

- يتم تنظيم هذه المعلومات بشكل هرمي بحيث يمكن لبروتوكول "SNMP" الوصول إليها بسرعة.

- يتم إعطاء كل معلومة داخل "MIB" معرفًا فريدًا (Object ID - OID).

- تنظم "MIB" المعرفات (OIDs) بناءً على معايير "RFC" ضمن تسلسل هرمي.

- المخطط التوضيحي (شريحة 105): يوضح التسلسل الهرمي لقاعدة "MIB" في سيسكو (Cisco MIB Hierarchy).

- ### اصدارات پروتوکول "SNMP" (SNMP Versions):

النموذج (Model)	مستوى الأمان (Level)	المصادقة (Authentication)	التشفير (Encryption)	النتيجة (Result)
SNMPv1	noAuthNoPriv	سلسلة المجتمع (stringCommunity)	لا يوجد	يستخدم مطابقة سلسلة المجتمع للمصادقة.
SNMPv2c	noAuthNoPriv	سلسلة المجتمع (stringCommunity)	لا يوجد	يستخدم مطابقة سلسلة المجتمع للمصادقة.

يستخدم مطابقة اسم المستخدم للمصادقة (يُعد تحسيناً مقارنة بـ SNMPv2c).	لا يوجد	اسم المستخدم (Username)	noAuthNoPriv	SNMPv3
يوفر مصادقة قائمة على خوارزميات HMAC-MD5 أو HMAC-SHA.	لا يوجد	خوارزمية MD5 أو SHA	authNoPriv	
يوفر مصادقة قائمة على خوارزميات HMAC-MD5 أو HMAC-SHA.	معيار DES أو AES	خوارزمية MD5 أو SHA	authPriv (يتطلب صورة برمجية "IOS" تدعم التشفير)	
يسمح بتحديد نموذج الأمان المستند إلى المستخدم (USM)، مع خوارزميات التشفير التالية:				
✓ تشفير DES 56-bit بالإضافة للمصادقة المبنية على معيار CBC-DES (DES-56).				
✓ تشفير 3DES 168-bit.				
✓ تشفير AES بطول 128 أو 192 أو 256 بت.				

• ثغرات بروتوكول "SNMP" (SNMP Vulnerabilities):

- الطلبات والإشعارات المرسلة ليست مصادقة أو مشفرة.

• مربع النص (شريحة 107):

• في إصدار "SNMPv1"، تُسمى تقارير الأحداث غير المتزامنة "فخاخ" (traps)، بينما تُسمى في الإصدارات اللاحقة "إشعارات" (notifications).

• نغير الإجراءات "get" (الاستعلام) و "set" (التعيين) هي الثغرات الأمنية التي تفتح بروتوكول "SNMP" أمام الهجمات.

❖ بروتوكول وقت الشبكة (Network Time Protocol - NTP)

- ضمان دقة الطوايع الزمنية (timestamping) لرسائل السجل، يجب مزامنة ساعات الأجهزة المضيفة وأجهزة الشبكة وصيانتها باستمرار.
- عادةً ما يتم ضبط إعدادات التاريخ والوقت للراوتر باستخدام إحدى الطريقتين:
 - تعديل التاريخ والوقت يدوياً (Manually editing).
 - تكوين بروتوكول وقت الشبكة (NTP).

↩ الفصل الثالث: المصادقة، التفويض، والمحاسبة (Authentication, Authorization, and Accounting)

❖ مصادقة "AAA" (AAA Authentication)

• أوضاع المصادقة (Authentication Modes):

مصادقة "AAA" المحلية (Local AAA Authentication)	مصادقة "AAA" المستندة إلى خادم (Server-Based AAA Authentication)
تستخدم قاعدة البيانات المحلية للمصادقة.	يحتوي خادم AAA المركزي على أسماء المستخدمين وكلمات المرور لجميع المستخدمين.
خطوات العملية (للتوضيح فقط):	خطوات العملية (للتوضيح فقط):
1. ينشئ العميل اتصالاً مع الراوتر.	1. ينشئ العميل اتصالاً مع الراوتر.
2. يطلب راوتر AAA من المستخدم إدخال اسم المستخدم وكلمة المرور.	2. يطلب راوتر AAA من المستخدم إدخال اسم المستخدم وكلمة مرور.
3. يصادق الراوتر على البيانات المدخلة باستخدام قاعدة البيانات المحلية (الخاصة به).	3. يصادق الراوتر على البيانات المدخلة باستخدام قاعدة البيانات المدخلة باستخدام خادم AAA مستقل.
4. يتم تفويض المستخدم للوصول إلى الشبكة بناءً على معلومات قاعدة البيانات المحلية.	4. يتم تفويض المستخدم للوصول إلى الشبكة بناءً على معلومات خادم AAA المستقل.

• بروتوكولات اتصالات "AAA" المستندة إلى خادم (Server-Based AAA Communication Protocols):

- يُعد كل من TACACS+ و RADIUS بروتوكولي مصادقة يُستخدمان للتواصل مع خوادم "AAA".

وجه المقارنة	بروتوكول "TACACS+"	بروتوكول "RADIUS"
الوظيفة (Functionality)	يفصل خدمات AAA وفقاً لبنية AAA، مما يسمح بنمذجة تطبيق خادم الأمن.	يدمج المصادقة والتفويض لكنه يفصل المحاسبة، مما يجعله أقل مرونة في التطبيق مقارنة بـ TACACS+.
المعيار (Standard)	مدعوم غالباً من سيسكو (Cisco supported).	معيار مفتوح (بواسطة RFC) (Open/RFC standard).
بروتوكول النقل (Transport Protocol)	يستخدم بروتوكول "TCP".	يستخدم بروتوكول "UDP".
بروتوكول المصادقة "CHAP"	تحد واستجابة (مصادقة) ثنائية الاتجاه (Bidirectional) كما هو مستخدم في "CHAP".	تحد واستجابة (مصادقة) أحادية الاتجاه (Unidirectional) من خادم RADIUS إلى عميل RADIUS.
دعم البروتوكولات (Protocol Support)	يدعم بروتوكولات متعددة (Multiprotocol support).	لا يدعم بروتوكول ARA أو NetBEUI.
السرية (Confidentiality)	تشفير الحزمة بأكملها (Entire packet encrypted).	تشفير كلمة المرور فقط (Password encrypted).
التخصيص (Customization)	يوفر تفويض أوامر الراوتر لكل مستخدم أو لكل مجموعة.	لا يوفر تفويض أوامر الراوتر لكل مستخدم أو لكل مجموعة.
المحاسبة (Accounting)	محدودة (Limited).	واسعة (Extensive).

■ ملاحظة للتوضيح: التحدي (Challenge): إرسال بيانات عشوائية أو مشفرة للتحقق، والاستجابة (Response): رد الطرف الآخر بجل أو توقيع لإثبات هويته.

❖ تفويض "AAA" (AAA Authorization)

• مقدمة إلى تفويض "AAA" المستند إلى الخادم (Introduction to Server-Based AAA Authorization):

المصادقة مقابل التفويض	المصادقة (Authentication): تضمن أن الجهاز أو المستخدم النهائي شرعي (مصرح له بالدخول).
(Authentication vs. Authorization)	التفويض (Authorization): يسمح أو يمنع المستخدم من المصادق عليهم من الوصول إلى مناطق وبرامج معينة على الشبكة.

بروتوكول "TACACS+" : يفصل المصادقة عن التفويض.
بروتوكول "RADIUS" : لا يفصل المصادقة عن التفويض.

"TACACS+" مقابل "RADIUS"
(TACACS+ vs. RADIUS)

الفصل الرابع : تطبيق تقنيات جدار الحماية (Implementing Firewall Technologies)

❖ قوائم الوصول/التحكم في الوصول (Access Lists - ACLs)

• نظرة عامة على قوائم الوصول (Access List Overview) :

○ ما هي قوائم الوصول (What Are Access Lists) ؟

➤ هي سلسلة متتالية من الأوامر أو الفلاتر (Filters).

➤ تحظر هذه القوائم الراوتر بأنواع الحزم التي يجب قبولها (accept) أو رفضها (deny).

➤ يمكن أن يعتمد القبول والرفض على شروط محددة مسبقاً.

➤ يتم تطبيق قوائم الوصول على واجهات الراوتر (Router's Interfaces).

○ العوامل المحددة لتطبيق قوائم الوصول :

➤ الموضع (Position) : واجهة الراوتر المحددة للتطبيق.

➤ الشرط (Condition) : السماح/الحظر (Permit/deny).

➤ الاتجاه (Direction) : وارد/صادر (In/Out).

➤ ترتيب العبارة (Arrangement of the statement) : تسلسل عبارات الفلتر في القائمة.

○ أمثلة لحالة السماح والحظر :

حالة الحظر لعنوان IP محدد فقط والسماح للبقية (Deny 172.16.20.1 only)		
ترتيب العبارات	الترتيب (A)	الترتيب (B)
	Access-list 5 permit any Access-list 5 deny 172.16.20.1	Access-list 5 deny 172.16.20.1 Access-list 5 permit any
للتوضيح فقط	غير فعال (لأن قاعدة السماح للجميع تسبق قاعدة الحظر وبالتالي سيمر العنوان دون فحص الحظر).	فعال (يحظر العنوان المحدد أولاً ثم السماح للجميع بعد ذلك).
حالة السماح لعنوان IP محدد فقط ورفض البقية (Permit 172.16.20.1 only)		
ترتيب العبارات	الترتيب (A)	الترتيب (B)
	Access-list 5 deny any Access-list 5 permit 172.16.20.1	Access-list 5 permit 172.16.20.1 Access-list 5 deny any
للتوضيح فقط	غير فعال.	فعال (للسماح للعنوان المطلوب أولاً ثم حظر كافة البيانات الأخرى).

○ السلوك الافتراضي لقائمة الوصول ← الحظر (Deny) (لكل العناوين غير المذكورة) :

➤ للتوضيح فقط : عبارة الحظر الضمني غير المرئية في نهاية القائمة هي : Access-list 5 deny any أو Access-list 5 deny 0.0.0.0 255.255.255.255.

➤ مثال : عند كتابة التكوين التالي فقط Access-list 5 permit 172.16.20.1 يعني هذا حظر أي عنوان آخر يطلب المرور تلقائياً.

○ يجب أن تحتوي قائمة الوصول على عبارة سماح (permit) واحدة على الأقل :

➤ للتوضيح فقط : إذا قمت بكتابة عبارات حظر فقط دون أي عبارة سماح ، فسيتم حظر كل حركة المرور بالكامل بسبب الحظر الضمني في النهاية.

➤ مثال : لحظر جهاز محدد والسماح للآخرين بالمرور :

Access-list 9 deny 172.16.20.1
Access-list 9 permit any

• لماذا نستخدم قوائم الوصول (Why Use Access Lists) ؟

○ إدارة حركة مرور "IP" (IP traffic) مع نمو الوصول إلى الشبكة.

○ تصفية الحزم (Filter packets) أثناء مرورها عبر الراوتر.

○ التخطيط النوضيحي (شريحة 160) : مثل بيئة شبكة مدمجة تشمل النطاقات 172.16.0.0 و 172.17.0.0 و FDDI و Token Ring ، ومرتبطة بالإنترنت عبر راوتر ومصفاة جدار حماية تلك الاختراقات وتأمين البيانات.

• تطبيقات قوائم الوصول (Access List Applications) :

○ السماح أو الحظر للحزم التي تتحرك عبر الراوتر.

○ السماح أو الحظر للوصول "VTY" من الراوتر أو إليه.

○ بدون قوائم الوصول ، يمكن إرسال جميع الحزم إلى كافة أجزاء الشبكة دون قيود.

• ما هي قوائم الوصول/الأنواع (What Are Access Lists/Types) ؟

قوائم الوصول القياسية (Standard)	تفحص عنوان المصدر (source) فقط.
قوائم الوصول الموسعة (Extended)	تسمح أو تحظر البروتوكولات بأكملها.
	تفحص عنوان المصدر (source) وعنوان الوجهة (destination).
	تسمح أو تحظر بروتوكولات محددة.
واردة أو صادرة (Inbound or Outbound)	يتم تحديد تطبيقها حسب اتجاه حركة المرور على واجهة الراوتر.

○ التخطيط النوضيحي (شريحة 162) : يوضح عمليات قائمة الوصول (Access List Processes) : حزمة واردة ، أمبير والوجهة ، البروتوكول ، هل مسموح؟ ، حزمة صادرة.

• نطاقات أرقام قوائم الوصول (Access List Number Ranges) :

الموسعة (Extended)	القياسية (Standard)
السماح أو الحظر لتطبيق محدد	"TCP" حزمة
100-199 & 200-2699	1-99 & 1300-1999

• إرشادات تكوين قوائم الوصول (ACL Configuration Guidelines) :

- أنشئ قائمة الوصول بشكل عام ، ثم طبقها على الواجهة المناسبة.
- تذكر أن العبارة الأخيرة في كل قائمة هي حظر الضمني للكل (deny any أو deny any).
- تذكر أن ترتيب العبارات داخل القائمة مهم ؛ لأن معالجة القوائم تتم من الأعلى إلى الأسفل (top-down) ، وبمجرد مطابقة العبارة (شرط معين) ، يتم الخروج من القائمة.
- تأكد من وضع العبارات الأكثر تحديداً (most specific) في أعلى القائمة.
- تذكر أنه يُسمح بتطبيق ACL واحدة فقط لكل واجهة ، ولكل بروتوكول ، ولكل اتجاه.
- تذكر أن العبارات الجديدة تُضاف إلى أسفل القائمة الحالية افتراضياً.
- تذكر أن الحزم المنشأة بواسطة الراوتر نفسه لا تخضع للتصفية بواسطة قوائم الوصول الصادرة (outbound).
- ضع قوائم الوصول القياسية (Standard) في أقرب مكان ممكن من الوجهة (destination).
- ضع قوائم الوصول الموسعة (Extended) في أقرب مكان ممكن من المصدر (source).

• مكافحة الانتحال بقوائم الوصول (Anti-spoofing with ACLs) :

- تعتمد معظم هجمات "DoS" على نوعاً من الانتحال (مثل انتحال عنوان IP).
- يتجاوز انتحال عنوان IP العملية العادية لإنشاء الحزم ، عبر إدراج ترويسة IP مخصصة (custom IP header) بعنوان IP مصدر مختلف.
- هناك العديد من فئات عناوين IP المعروفة التي لا ينبغي أبداً اعتبارها كعناوين مصدر لحركة المرور الواردة إلى شبكة المؤسسة.

• تخفيف إساءة استخدام بروتوكول "ICMP" (Mitigating ICMP Abuse) :

- يمكن للمخترقين استخدام :
 - حزم صدى بروتوكول "ICMP" (echo packets) (أوامر Ping) لاكتشاف الشبكات الفرعية.
 - رسائل إعادة توجيه "ICMP" (redirect messages) لتغيير جداول توجيه المضيفين (الأجهزة المصابة).
- يجب حظر كل من رسائل الصدى وإعادة التوجيه لبروتوكول "ICMP" الواردة بواسطة الراوتر (تجنب الاستكشاف والتعديل غير المصرح به).

• تخفيف استغلال بروتوكول "SNMP" (Mitigating SNMP Exploits) :

- يمكن تخفيف ثغرات "SNMP" عبر تطبيق قوائم الوصول على الواجهات ، لتصفية حزم "SNMP" القادمة من الأنظمة غير المصرح بها.
- قد يظل الاستغلال ممكناً إذا كانت حزمة "SNMP" مصدرها من عنوان تم انتحاله ومسموح به في قائمة الوصول.
- لذلك ، فإن الطريقة الأكثر فاعلية لمنع الاستغلال هي تعطيل خادم "SNMP" على أجهزة "IOS" التي لا تتطلبه.
- أمر التعطيل : Router(config)# no snmp-server.

• جدران الحماية (Firewalls) :

- مفهوم جدران الحماية (Defining Firewalls) :
 - كان مصطلح "جدار الحماية" (Firewall) في الأصل يُشير إلى جدار مقاوم للحريق ، مصنوع عادةً من الحجر أو المعدن الذي يمنع انتشار النيران إلى الهياكل المتصلة.
 - تشترك جميع جدران الحماية في بعض الخصائص المشتركة (All firewalls share some common properties) :
 - مقاومة للهجوم.
 - تمثل نقطة العبور الوحيدة بين الشبكات ، لأن جميع حركات المرور تمر عبرها (مما يعني أنها تفحص كل حزمة).
 - تفرض سياسات التحكم بالوصول.
 - يُعد جدار حماية تصفية الحزم (Packet Filtering) هو الشكل الأول لجدار حماية الشبكة (network firewall).

○ فوائد وقيود جدران الحماية (Benefits and Limitations of Firewalls) :

- تفرض جدران الحماية بعض القيود المحددات :
 - يمكن أن يكون لجدار الحماية سبب في تكوين عواقب وخيمة على الشبكة.
 - حيث لا يمكن تمرير بيانات العديد من التطبيقات عبر جدران الحماية بشكل آمن ، مما قد يُبطئ أداء الشبكة.
 - أيضاً يمكن تمرير حركة المرور غير المصرح بها عبر أنفاق (Tunneled) أو إخفاؤها عبر جدار الحماية.

➤ المخطط التوضيحي (شريحة 178) :

✓ حظر جميع حركات المرور الواردة التي تحمل عناوين شبكة نطاق عناوين IP مسجلة داخلياً (طعن انتحال عناوين IP).	✓ السماح لحركة المرور من أي عنوان خارجي إلى خادم الويب (Web Server).
✓ حظر جميع حركات المرور الواردة إلى الخادم من العناوين الخارجية.	✓ السماح لحركة المرور إلى خادم FTP (FTP Server).
✓ حظر جميع حركات المرور الواردة الخاصة بطلبات صدى ICMP (ICMP Echo Request) (أوامر Ping).	✓ السماح لحركة المرور إلى خادم SMTP (SMTP Server).
✓ حظر جميع حركات المرور الواردة الخاصة بخدمات الدليل النشط ميكروسوفت (MS Active Directory).	✓ السماح لحركة المرور إلى خادم IMAP الداخلي (Internal IMAP Server).
✓ حظر جميع حركات المرور الواردة إلى منافذ خادم قواعد بيانات MS SQL (MS SQL Server Ports).	
✓ حظر جميع عمليات البث المحلي لنطاق ميكروسوفت (MS Domain Local Broadcasts).	

❖ أنواع جدران الحماية (Types of Firewalls)

المخطط التوضيحي (شريحة 180): أنواع جدران الحماية وفقاً للطبقات التي تعمل عليها:

جدار حماية تصفية الحزم (Packet Filtering Firewall)	طبقة الشبكة (Layer 3)، طبقة النقل (Layer 4).	يفحص العناوين والمنافذ فقط.
جدار حماية بوابة التطبيقات (Application Gateway Firewall)	طبقة الشبكة (Layer 3)، طبقة النقل (Layer 4)، طبقة الجلسة (Layer 5)، طبقة التطبيقات (Layer 7).	يفحص محتوى البروتوكولات والأوامر المحددة.
جدار الحماية ذو الحالة (Stateful Firewall)	طبقة الشبكة (Layer 3)، طبقة النقل (Layer 4)، طبقة الجلسة (Layer 5).	يتتبع حالة الاتصالات وجدول الجلسات النشطة من طبقة الشبكة وحتى طبقة التطبيقات، لتحديد مصداقية البيانات العائدة.
جدار حماية ترجمة عناوين الشبكة (NAT Firewall)	طبقة الشبكة (Layer 3)، طبقة النقل (Layer 4).	يجمى الشبكة الداخلية عن طريق إخفاء وتعديل عناوين IP الخاصة بالأجهزة الداخلية وتحويلها لعناوين عامة.

• جدار حماية تصفية الحزم (عديم الحالة) (Packet Filtering (stateless) Firewall):

○ الفوائد والقيود (Benefits & Limitations):

المخطط التوضيحي (شريحة 181):

يعمل هذا النوع من خلال تقييم المعايير الأساسية التالية لكل حزمة بشكل مستقل: (معايير الفحص) ↓↓↓

✓ عنوان IP المصدر (Source IP address).

✓ عنوان IP الوجهة (Destination IP address).

✓ البروتوكول المستخدم (Protocol).

✓ رقم منفذ المصدر (Source port number).

✓ رقم منفذ الوجهة (Destination port number).

✓ استلام حزمة بدء الاتصال (Synchronize/Start [SYN] packet receipt).

■ الفوائد: كفاءة عالية وسرعة في المعالجة، ثقلها منخفض.

■ القيود: لا ينتج حالة الاتصال للجلسات المفتوحة، مما يسهل استهدافه بالترفيف، ولا يمكنه قراءة أو فحص بيانات طبقة التطبيقات.

• جدران الحماية ذات الحالة (Stateful Firewalls):

○ المخطط التوضيحي (شريحة 182):

تتميز جدران الحماية ذات الحالة (Stateful Firewalls) بتسجيلها على تسجيل الجلسات النشطة في جدول الجلسات الخاص بها (State Tables).

ألية العمل (Stateful Firewall Operation): عندما يقوم جهاز داخلي ببدء اتصال مع خادم خارجي عبر المنفذ 80، يتم تسجيل تفاصيل الجلسة في جدول الجلسات. ونسمح القواعد الخارجية لتقانياً بمرور حركة البيانات الراجعة بشرط مطابقتها للثمة لبيانات الجلسة المسجلة بجدول الحالة دون الحاجة لفتح المنافذ الخارجية بشكل دائم.

○ الفوائد والمحددات (Benefits and Limitations):

الفوائد (Benefits)	القيود (Limitations)
■ وسيلة أساسية للدفاع.	■ لا تدعم فحص طبقة التطبيقات.
■ تصفية قوية للحزم.	■ لا يمكنها تصفية البروتوكولات عديمة الحالة (stateless).
■ أداء أفضل مقارنة بمرشحات الحزم (عديمة الحالة).	■ صعوبة الدفاع ضد التفاوض الديناميكي على المنافذ.
■ الدفاع ضد هجمات الانتحال (spoofing) وحجب الخدمة (DoS).	■ لا تدعم المصادقة.
■ سجل بيانات مفصلة وغنية.	

• جدران الحماية من الجيل التالي (Next Generation Firewalls - NGFWs):

○ الفوائد (Benefits):

➤ التعرف الدقيق، والرؤية، والتحكم في سلوكيات التطبيقات.

➤ تقييم استخدام الويب وتطبيقات الويب بناءً على سمعة الموقع.

➤ الحماية الاستباقية ضد تهديدات الإنترنت.

➤ فرض السياسات بناءً على: المستخدم، الجهاز، الدور، نوع التطبيق، وملف التهديد (threat profile).

➤ تنفيذ ترجمة عناوين الشبكة (NAT)، والشبكات الافتراضية الخاصة (VPN)، والفحص المعتمد على الحالة للحزم (SPI).

➤ استخدام نظام منع التسلل (IPS).

○ يُطلق على "Cisco ASA" المزود بخدمات "FirePOWER" اسم "جدار حماية الجيل التالي من Cisco ASA" (Cisco ASA Next-Generation Firewall)، لأنه جدار حماية تكيفي يركز على التهديدات (Threat-focused).

• جدار الحماية الكلاسيكي (Classic Firewall):

○ مقدمة إلى جدار الحماية الكلاسيكي (Introducing to Classic Firewall):

➤ عُرف جدار حماية "Cisco IOS" الكلاسيكي (Cisco IOS Classic Firewall) سابقاً باسم "التحكم بالوصول المعتمد على السياق" (Context-Based Access Control - CBAC).

➤ هو ميزة لجدار الحماية ذي الحالة (stateful firewall) أُضيفت إلى نظام تشغيل "Cisco IOS" قبل الإصدار 12.0.

➤ يوفر جدار الحماية الكلاسيكي 4 وظائف رئيسية (provides four main functions):

■ تصفية حركة المرور (traffic filtering).

■ فحص حركة المرور (traffic inspection).

■ كشف التسلل (intrusion detection).

■ إنشاء عمليات التدقيق والتنبيهات (generation of audits and alerts).

آلية عمل جدار الحماية الكلاسيكي (Classic Firewall Operation):

أ. التخطيط التوضيحي (شريحة 185): تسلسل عمليات جدار الحماية الكلاسيكي عند محاولة إنشاء اتصال SSH خارجي:

- الخطوة 1: فحص ACL الواردة (Inbound ACL) على المنفذ 22 (SSH) لتحديد ما إذا كان يُسمح لطلبات SSH بمغادرة الشبكة. (طلب جلسة SSH)
- الخطوة 2: يقارن IOS نوع الحزمة بقواعد الفحص (Inspection rules) لتحديد ما إذا كان يجب تثبيت جلسة الـ SSH.
- الخطوة 3: يضيف معلومات الجلسة إلى جدول الحالة (State table) لتتبع جلسة الـ SSH.
- الخطوة 4: يضيف إدخالاً ديناميكياً إلى ACL الواردة على المنفذ 22 للسماح لحزم الرد بالعودة إلى الشبكة الداخلية.
- الخطوة 5: عندما يقوم العميل (Client) بإنهاء الجلسة، يحذف الراوتر فوراً إدخال الحالة (نفاذ الجلسة) من جدول الحالة وإدخال الديناميكيات الموقوتة من ACL.

تكوين جدار الحماية الكلاسيكي (Classic Firewall Configuration):

أ. قواعد الفحص (Inspection Rules):

- تحديد الواجهات الداخلية والخارجية.
- تكوين قوائم الوصول (ACLs) لكل واجهة.
- تحديد قواعد الفحص (Inspection Rules).
- تطبيق قواعد الفحص على الواجهة المناسبة.

الشبكات الداخلية والخارجية (Inside and Outside Networks):

- يتم حظر حركة المرور القادمة من الشبكة العامة (خارجية/غير موثوقة) والمتجهة نحو الشبكة الخاصة بشكل عام.
- يسمح لحركة المرور القادمة من الشبكة الخاصة (داخلية/موثوقة) ويتم فحصها أثناء اتجاهها نحو الشبكة العامة.
- يسمح لحركة المرور المخصصة العائدة من الشبكة العامة والمتجهة نحو شبكتك "DMZ" بشكل انتقائي بناءً على متطلبات الخدمة.

المناطق منزوعة السلاح/المعزولة أمنياً (DMZs - Demilitarized Zones):

- عادةً يتم حظر حركة المرور الصادرة من شبكة "DMZ" والمتجهة نحو الشبكة الخاصة.
- يسمح لحركة المرور الصادرة من شبكة "DMZ" والمتجهة نحو الشبكة العامة بشكل انتقائي بناءً على متطلبات الخدمة.
- يسمح لحركة المرور الصادرة من الشبكة العامة والمتجهة نحو شبكة "DMZ" بشكل انتقائي ويتم فحصها (تستهدف خوادم الويب أو البريد عادةً).

جدران الحماية القائمة على سياسات المناطق (Zone-Based Policy Firewalls - ZPF):

- المنطقة (Zone): هي مجموعة من واجهة واحدة أو أكثر ذات وظائف أو خصائص متشابهة.
- يتم حظر جميع حركات المرور بين منطقة إلى أخرى (Zone-to-Zone) بشكل افتراضي، وللسماح بحركة المرور بين المناطق، يجب تكوين سياسة تسمح بحركة المرور أو تفحصها (Inspection).

المنطقة الذاتية (The Self Zone):

- هي الراوتر نفسه (the router itself) وتشمل جميع عناوين IP لواجهات الراوتر.
- هذا يعني أن حركة المرور المتدفقة من وإلى عناوين IP لواجهات الراوتر لا تخضع في البداية لسياسات المناطق (ما لم يتم تخصيص سياسات محددة لها).

❖ أنظمة كشف ومنع التسلل (IDS and IPS)

هجمات يوم الصفر (Zero-Day Attacks):

- يُعرف هجوم يوم الصفر بأنه: ثغرة في البرمجيات تكون غير معروفة للمطور (Vendor)، والتي يستغلها المخترق قبل أن يكتشفها المطور ويسرع لإصلاحها.
- يمكن لجدران الحماية (Firewalls) القيام بهام محددة فقط، ولا يمكنها الحماية من البرمجيات الخبيثة (Malware) وهجمات يوم الصفر (Zero-Day Attacks).

مراقبة الهجمات (Monitor for Attacks) - نظام كشف التسلل (IDS):

- تُعد مراقبة الشبكة وتحليل ملفات السجل (Log Files) إحدى طرق حماية الشبكة من الديدان (Worms) والفيروسات (Viruses)، لكنها مهمة تستغرق وقتاً طويلاً.
- يتم تنفيذ نظام كشف التسلل (IDS) لمراقبة حركة المرور على الشبكة بشكل سلبي/غير مباشر (Passively).
- مزايا نظام كشف التسلل (Advantages of IDS):
 - يعمل بشكل سلبي (العمل دون اتصال بالمسار المباشر/الوضع المختلط "Offline/Promiscuous Mode").
 - يتطلب عكس حركة المرور (Mirrored) لتصل إليه.
 - لا تثر حركة مرور الشبكة عبر نظام "IDS" إلا إذا تم عكسها.
 - لا يؤثر سلباً على تدفق حزم حركة المرور المُعاد توجيهها (لا يُحدث تأخيراً).
 - يقوم بنسخ تدفق حركة المرور وتحليل حركة المرور المنسوخة بدلاً من فحص الحزم الفعلية المُعاد توجيهها.

كشف الهجمات وإيقافها (Detect and Stop Attacks) - نظام منع التسلل (IPS):

- على عكس "IDS"، يتم تنفيذ نظام منع التسلل (IPS) في الوضع المضمن المباشر (Inline Mode).
- هذا يعني أن جميع حركات المرور الواردة (ingress) والصادرة (egress) يجب أن تمر عبره للمعالجة.
- تستخدم منصات "Cisco IPS" مزيجاً من تقنيات الكشف، بما في ذلك:
 - الكشف القائم على التوقيعات (Signature-Based).
 - الكشف القائم على ملفات السلوك (Profile-Based).
 - الكشف القائم على تحليل البروتوكولات (Protocol Analysis-Based).

○ مزايا نظام منع التسلسل (Advantages of IPS)؛

- يتم تنفيذه في وضع مضمن مباشر (Inline Mode).
- يراقب حركة مرور الطبقة الثالثة (Layer 3) والرابعة (Layer 4).
- يمكنه منع هجمات الحزمة الفردية (Single Packet) من الوصول للهدف.
- يستجيب فوراً، ولا يسمح بمرور أي حركة مرور خبيثة.

● أوجه التشابه بين "IDS" و "IPS" (Similarities Between IDS and IPS)؛

○ مربع النص (شرح 194) : الخصائص المشتركة بين "IDS" و "IPS" : (Common Characteristics of IDS and IPS)؛

- كلا التقنيتين يتم نشرها كحساسات (Sensors).
- كلا التقنيتين تستخدم التوقيعات (Signatures) لاكتشاف أنماط سوء الاستخدام الخبيث في حركة مرور الشبكة.
- كلاهما يمكنهما اكتشاف الأنماط البسيطة (Atomic Patterns) – "حزمة فردية" أو الأنماط المعقدة (Composite Patterns) – "حزم متعددة".

○ يمكن أن يكون مستشعر نظام "IDS" أو "IPS" أيًا من الأجهزة التالية (An IDS or IPS sensor can be any of the following devices)؛

- راوتر (Router) مجهز ببرمجية "Cisco IOS IPS".
- جهاز مصمم (Appliance designed) خصيصاً لتقديم خدمات "IDS" أو "IPS" مخصصة.
- وحدة شبكة (Network module) مثبتة داخل جهاز أمان تكييفي (ASA)، أو سويتش (Switch)، أو راوتر (Router).

● مزايا وعيوب "IDS" و "IPS" (Advantages and Disadvantages of IDS and IPS)؛

وجه المقارنة	نظام كشف التسلسل (IDS)	نظام منع التسلسل (IPS)
المزايا (Advantages)	➤ لا يوجد تأثير على الشبكة. ➤ لا تتأثر الشبكة عند تعطل المستشعر (sensor failure). ➤ لا تتأثر الشبكة عند التحميل الزائد (overload) على المستشعر.	➤ يوقف الحزم المُحفَّزة للهجوم (trigger packets). ➤ يمكنه استخدام تقنيات "تطبيع التدفق" (Stream Normalization)؛ وهي تقنية تُستخدم لإعادة بناء تدفق البيانات عند وقوع الهجوم على أجزاء بيانات متعددة (مثل إعادة تجميع التفرقة للتحقق من صحة الإرسال).
العيوب (Disadvantages)	➤ لا يمكن لأجراء الاستجابة إيقاف المُحفَّز للهجوم (trigger). ➤ يتطلب ضبطاً دقيقاً (tuning) لإجراءات الاستجابة. ➤ أكثر عرضة لتقنيات التهرب (evasion techniques) من أمن الشبكة.	➤ يوجد بعض التأثير على الشبكة. ➤ قد تؤثر مشكلات المستشعر على حركة مرور الشبكة. ➤ تتأثر الشبكة عند التحميل الزائد (overload) على المستشعر.

○ الخلاصة: يُعد نظام "IPS" أداة تحكم (Control Tool)، بينما يُعد نظام "IDS" أداة رؤية (Visibility Tool).

● هناك نوعان رئيسيان من أنظمة "IPS" (There are two primary kinds of IPSs)؛

وجه المقارنة	نظام "IPS" المعتمد على المضيف (HIPS)	نظام "IPS" المعتمد على الشبكة (NIPS)
المفهوم (Defining)	➤ هو برنامج مثبت على مضيف واحد لمراقبة وتحليل النشاط المشبوه. ➤ يمكنه مراقبة النشاط المشبوه ومنع المضيف من تنفيذ الأوامر التي لا تتطابق مع السلوك المعتاد. ➤ عيبه: أنه يعمل فقط على المستوى المحلي للجهاز، ولا يمتلك رؤية كاملة للشبكة.	➤ يمكن تنفيذه باستخدام جهاز "IPS" مخصص أو غير مخصص (مثل إضافته إلى راوتر "ISR"، أو جدار حماية "ASA"، أو سويتش "Catalyst 6500"). ➤ تُعد تطبيقاته عنصراً أساسياً لمنع التسلسل. ➤ بالرغم من وجود حلول "IDS/IPS" معتمدة على المضيف، إلا أنه يجب دمجها مع حلول "NIPS" لضمان بناء بنية أمنية قوية.
المزايا (Advantages)	➤ يوفر حماية خاصة بنظام تشغيل المضيف (host OS). ➤ يوفر حماية على مستوى نظام التشغيل والتطبيق. ➤ يجمي المضيف بعد فك تشفير الرسالة.	➤ فعال من حيث التكلفة (Cost-effective). ➤ مستقل عن نظام التشغيل (يجمي بيانات تشغيل متعددة). ➤ غير مرئي على الشبكة. ➤ يتيح رصد أحداث الشبكة في المستويات أدنى.
العيوب (Disadvantages)	➤ يعتمد على نوع نظام التشغيل. ➤ يجب تثبيته على كل الأجهزة المضيئة.	➤ لا يمكنه فحص حركة المرور المشفرة. ➤ يجب عليه إيقاف حركة المرور الخبيثة قبل وصولها إلى المضيف. ➤ لا يمكنه تحديد ما إذا كان الهجوم ناجحاً أم لا.

● حلول أنظمة "IPS" النمطية والمعتمدة على أجهزة مخصصة من سيسكو (Cisco's Modular and Appliance-Based IPS Solutions)؛

- Cisco IPS AIM and IPS NME.
- Cisco ASA AIP-SSM.
- Cisco IPS 4300 Series Sensors.
- Cisco Catalyst 6500 Series IDSM-2.

○ العوامل المؤثرة في اختيار ونشر مستشعر "IPS" (Factors affecting the IPS sensor selection and deployment)؛

- حجم حركة مرور الشبكة (Amount of network traffic).
- طوبولوجيا الشبكة (Network topology).
- ميزانية الأمن (Security budget).
- الكوادر الأمنية المتاحة لإدارة نظام "IPS" (Available security staff).

- مقدمة إلى الشبكات الافتراضية الخاصة (Introducing VPNs):
 - تعريف شبكة "VPN": هي شبكة خاصة تُنشأ عبر نفق (tunneling) على شبكة عامة، وتكون عادةً الإنترنت.
 - تُعتبر شبكة "VPN" افتراضية (Virtual) من حيث أنها تنقل المعلومات كما لو كانت داخل شبكة خاصة، ولكن يتم نقل هذه المعلومات فعلياً عبر شبكة عامة.
 - تُعتبر شبكة "VPN" خاصة (Private) من حيث أن حركة المرور مشفرة (encrypted) للحفاظ على سرية البيانات أثناء نقلها عبر الشبكة العامة.
 - فوائد شبكة "VPN" (VPN Benefits):
 - توفير التكاليف (Cost Savings).
 - الأمن (Security).
 - قابلية التوسع (Scalability).
 - التوافقية (Compatibility).

• شبكات "IPsec VPN" في الطبقة الثالثة (Layer 3 IPsec VPNs):

- توفر خدمات "IPsec":
 - المصادقة (Authentication).
 - السلامة/النكاملية (Integrity).
 - السرية (Confidentiality).
 - التحكم بالوصول (Access Control).
- باستخدام "IPsec"، يمكن تشفير المعلومات المتبادلة بين المواقع البعيدة والتحقق منها.
- أمثلة على شبكات "VPN" في الطبقة الثالثة (Examples of Layer 3 VPNs):
 - بروتوكول التغليف العام للتوجيه (Generic Routing Encapsulation - GRE).
 - التبديل متعدد البروتوكولات (Multi-Protocol Label Switching - MPLS).
 - أمن بروتوكول الإنترنت (Internet Protocol Security - IPsec).